

# Звіт з усунення вразливостей (Security Remediation Report)

Проект: BeeProcess (Process Mapper) Дата: 06 жовтня 2026 р.

## Огляд

Під час аудиту безпеки було виявлено 28 зауважень, які охоплювали критичні проблеми авторизації, управління сесіями, валідації даних та криптографії. Усі вразливості були успішно усунуті.

## Детальний перелік виправлень

### 1. Авторизація та Контроль доступу (BOLA / IDOR / RBAC)

- Пункти 3, 4, 5: Закрито BOLA (Insecure Direct Object Reference) на ендпоінтах отримання деталей процесу, кроків та KPI.
- Пункти 6, 7: Виправлено обхід рольової моделі (RBAC Bypass) при отриманні списку процесів.
- Пункт 8: Додано перевірку ролі ( `isAnalystOrAdmin` ) для ендпоінту створення рівнів ( `POST /api/levels` ), який раніше був доступний будь-кому.
- Пункти 10, 11: Додано перевірку сесії ( `getSession()` ) на ендпоінтах `/api/architecture` та `/api/wiki` , які раніше пропускали будь-які запити з підробленою кукою.
- Пункт 20: Створено єдиний центр управління політиками доступу ( `src/lib/permissions.ts` ), що вирішило проблему "розмазаності" по ендпоінтах авторизації.

### 2. Управління сесіями (Session Management)

- Пункт 9: Додано строгу верифікацію криптографічного підпису (HMAC-SHA256 через Web Crypto API) на рівні `middleware.ts` .
- Пункт 12: Реалізовано Server-Side Session Expiration. У підпис сесії додано мітку часу (`expiresAt`).
- Пункт 13: Додано механізм відкликання сесій (Session Revocation). Сесії стали stateful (таблиця `Session` в БД), що дозволило автоматично "викидати" користувача при зміні пароля чи видаленні акаунту.
- Пункт 14: Зроблено Session Rotation. При кожному логіні генерується новий унікальний `sessionId` .

### 3. Захист аутентифікації та LDAP

- Пункт 1: Видалено хардкод Plaintext-паролів при авторизації.
- Пункт 15: Впроваджено DB-backed Rate Limiter на ендпоінті `/api/auth` (захист від Brute-force та Password Spraying).
- Пункт 16: Заборонено відкат на локальну авторизацію, якщо налаштовано LDAP (щоб уникнути обходу блокувань в Active Directory).
- Пункт 17: У production-середовищі жорстко заборонено використання `ldap://` (CWE-319), дозволено лише захищений `ldaps://` .
- Пункт 18: Додано жорстку політику паролів (мінімум 8 символів, літери + цифри, максимум 72 символи).

### 4. Валідація даних та Безпека API

- Пункт 22: Реалізовано перевірку схем URL ( `bpnmUrl` , `docUrl` ) — дозволено лише HTTP/HTTPS, що блокує ін'єкцію `javascript:` (XSS).

- **Пункт 23:** Додано жорстку структурну валідацію та ліміти (розмір, вкладеність) для JSON-корисного навантаження в `/api/architecture` для запобігання DoS.
- **Пункт 24:** Інтегровано бібліотеку `Zod` для суворої валідації вхідних даних (реалізовано для Wiki).
- **Пункт 19:** Вирішено проблему Excessive Data Exposure — список користувачів ( `GET /api/users` ) більше не віддає всі дані всім ролям.

## 5. Інфраструктура, Логування та Hardening

- **Пункт 2:** Прибрано хардкод фолбеку `SESSION_SECRET` для продакшену.
- **Пункт 21:** З продакшен-політики CSP (Content-Security-Policy) видалено небезпечну директиву `unsafe-eval`.
- **Пункт 25:** Виправлено витік технічних деталей бази даних при помилках (Internal DB Error Disclosure).
- **Пункт 26:** Самописне порівняння HMAC замінено на безпечний нативний примітив `crypto.timingSafeEqual()`.
- **Пункт 27:** Додано заголовки `Cache-Control: no-store` для всіх `/api/` роутів.
- **Пункт 28:** Створено систему повноцінного аудиту ( `SecurityAuditLog` ) для критичних подій безпеки.

## Висновок

Систему BeeProcess переведено в стан високої захищеності (Enterprise-ready). Відсутність CVE у ключових залежностях підтверджує надійність технологічного стеку.

---

*Згенеровано автоматично асистентом Antigravity*